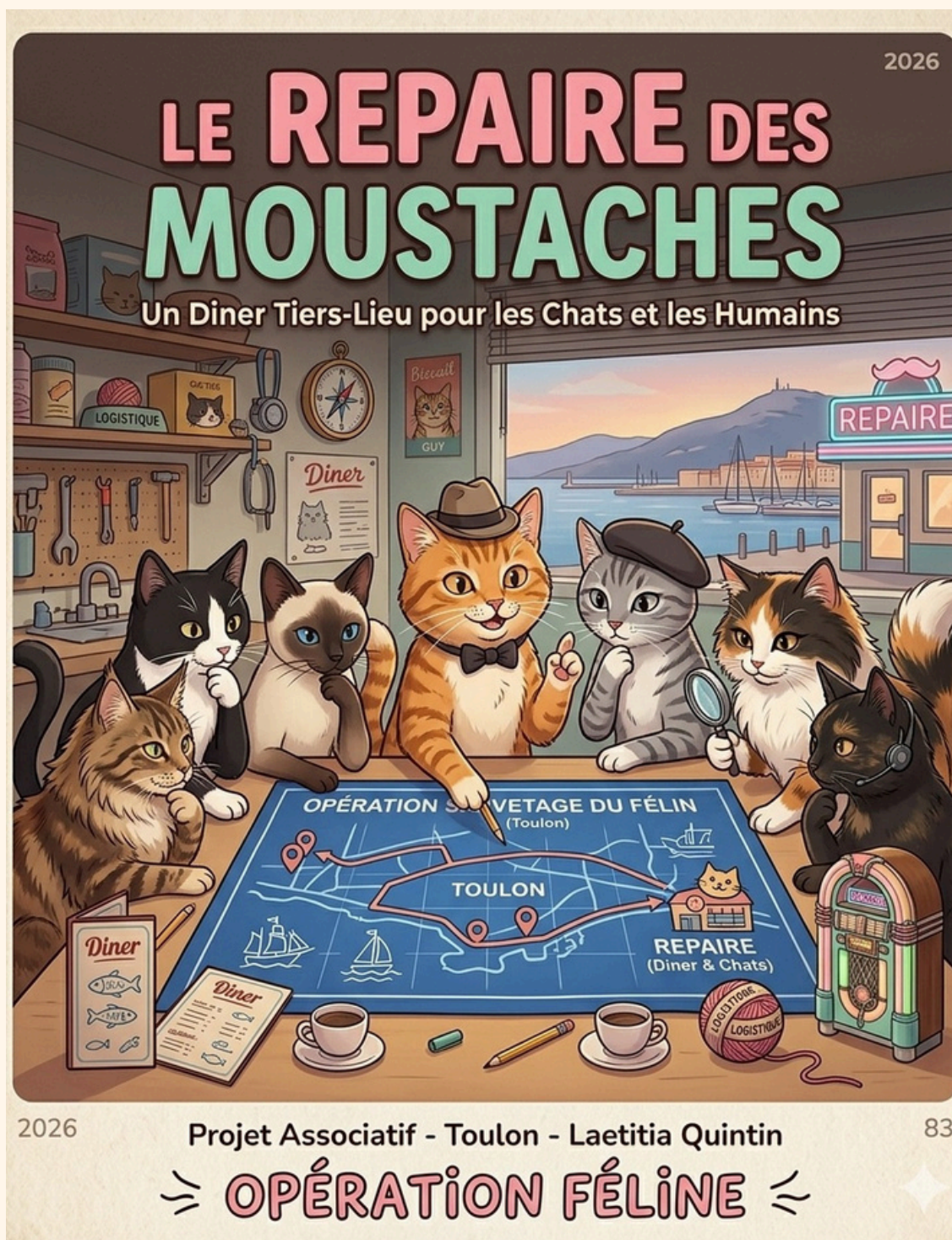




Dossier de Projet Professionnel —Session2026

Titre Professionnel Développeur Web et Web Mobile (Niveau 5)

Développé par : Laetitia QUINTIN

Sommaire Technique



Présentation & Vision

Tiers-Lieu Solidaire :
Concept 3-en-1 éco-
conçu implanté à Toulon.
Le Diner : Restauration
rétro (50s) assurant
l'autofinancement.
Refuge Félin : Espace
d'immersion,
ronronthérapie et
adoptions.
Ateliers Citoyens :
Partage de savoirs et
bricolage à prix libre.



Architecture & BDD Développement Native

: PHP 8.2 (POO/PDO)
sans framework.
Frontend : HTML5
sémantique, CSS3
(Grid/Flex) et JavaScript.
Base de Données :
Modèle relationnel
MySQL structuré sur 13
tables.
Architecture : Dossier
/public isolé pour
protéger le cœur
applicatif.



Sécurité & Conformité

Normes OWASP :
Protection XSS, requêtes
préparées et jetons CSRF.
Uploads Sécurisés :
Vérification stricte des
types MIME des fichiers.
Conformité RGPD : Mots
de passe hachés avec
l'algorithme BCrypt.
Accessibilité (WCAG) :
Navigation 100% clavier et
contrastes respectés.



Audits & Perspectives

Scores Lighthouse : 92%
Performance, 92%
Accessibilité, 91% SEO.
Éco-conception : Images
WebP et chargement
différé (lazy loading).
Évolutions V2 : Transition
vers une architecture MVC
avec ORM.
Futures Features :
Paiement en ligne (Stripe)
et réservation d'ateliers.

Reconversion Engagée

Ma vision du numérique

J'ai souhaité marier l'accompagnement social aux opportunités du numérique :

Mon impact social & local : J'ai placé le lien humain et la cause animale au cœur de mes lignes de code pour Toulon.

Ma maîtrise technique : Je me suis appropriée l'ingénierie web native (PHP 8.2 / JS Vanilla) sans framework, pour garantir une souveraineté technique totale.

Mon sérieux & ma curiosité : J'ai allié sobriété logicielle, sécurité (OWASP) et conformité d'accessibilité universelle (WCAG 2.1 AA) tout au long du développement.



Problématique & Objectifs



Mon Constat

📌 **Isolement & Saturation :**

J'ai observé un isolement social croissant au centre-ville de Toulon ainsi qu'une saturation chronique des refuges animaliers locaux.

⚙️ **Lacune Logistique :** J'ai constaté que ces structures bénévoles manquent cruellement d'outils numériques fluides pour gérer leur logistique et leur communication.



Mes 3 Objectifs

🐱 **Vitrine Féline :** Je veux multiplier les adoptions responsables grâce à l'espace d'immersion que j'ai imaginé.

🔄 **Modèle Vertueux :** J'ambitionne de financer l'entraide sociale directement par l'activité commerciale du diner.

🤝 **Partage & Inclusion :** Je souhaite briser l'isolement en proposant des ateliers accessibles à tous, à prix libre.

Concept & Vision Stratégique

Mon projet de tiers-lieu solidaire : J'ai imaginé une alliance unique entre un restaurant rétro, un refuge félin et un espace citoyen.

Forces : Identité visuelle forte, multi-activités.

Faiblesses : Logistique complexe (HACCP/Hygiène).

Opportunités : Subventions Innovation Sociale PACA.

Menaces : Réglementations sanitaires strictes.



Les 4 Piliers du Repaire des Moustaches



Diner Rétro :

J'ai pensé cet espace de restauration conviviale pour ancrer le projet dans la culture locale et assurer son autofinancement.



Refuge Solidaire :

J'ai créé cette zone d'immersion interactive pour sensibiliser les visiteurs et faciliter les adoptions responsables.



Ateliers Citoyens :

J'anime ce lieu de transmission de savoirs manuels pour créer du lien social et sensibiliser à la cause animale.



Boutique Éco :

J'ai intégré un espace de distribution dédié aux produits éthiques, durables et issus de l'artisanat local.

Nos Utilisateurs



Les Toulonnais

Je m'adresse aux habitants en recherche de lien social et de convivialité dans un espace inclusif.



Futurs Adoptants

J'accompagne les familles prêtes pour une adoption responsable, en confiance et sur mesure.



Clients Solidaires

Je vise les consommateurs éthiques, sensibles à la cause locale et au zéro déchet.



Les Bénévoles & Staff

J'ai conçu pour l'équipe du lieu un back-office simple et intuitif pour faciliter leur quotidien.

Cahier des Charges MVP



Espace Public Client



- 🐱 *Galerie chats* : J'ai développé une vue immersive et filtrable pour faciliter les adoptions.
- 📅 *Ateliers* : J'ai intégré un module de réservation en ligne pour les événements solidaires.
- 🛒 *Panier* : J'ai conçu un panier d'achat interactif et asynchrone (AJAX/Fetch).



Espace Administration



- 🔒 *Sécurité* : J'ai sécurisé l'authentification avec le hachage des mots de passe (password_hash).
- 📊 *Suivi* : J'ai mis en place un dashboard d'activité (commandes et réservations).
- ⚙️ *Gestion* : J'ai codé les opérations CRUD complètes sur les ateliers, produits et chats.
- 💬 *Modération* : J'ai ajouté la validation et le contrôle des "Belles Histoires".

User Stories & Priorisation

US	Rôle	Fonctionnalité (En tant que...)	Priorité	Critères d'acceptation
US_01	Visiteur	Consulter les pensionnaires à l'adoption	● Haute	Filtres dynamiques & statut visible
US_02	Visiteur	Ajouter au panier sans rechargement	● Haute	Requête AJAX & mise à jour UI
US_03	Visiteur	Réserver un atelier en ligne	● Haute	Calcul des places en temps réel
US_04	Admin	Authentification sécurisée au back-office	● Haute	session_regenerate_id() & BCrypt
US_05	Admin	Gestion CRUD (Pensionnaires, Ateliers)	● Haute	Requêtes préparées PDO & upload MIME
US_06	Admin	Modération des témoignages	● Moyenne	Système de validation avec statuts BDD

Logo, déclinaisons et responsive UI

🎨 Identité Visuelle & Adaptabilité :

Logo Principal : Un style néon rétro arrondi, chaleureux et mémorable, pensé comme l'enseigne emblématique du Diner.

Déclinaisons : Badges circulaires, versions monochrome/monochromes simplifiées et formats compacts adaptés aux réseaux sociaux, au responsive UI et au favicon.

Objectif : Ancrer un univers de marque fort, immédiatement reconnaissable et déclinable sur tous les supports (web et print).



LE REPAIRE DES MOUSTACHES
DINER & CHATS
EST. 2024

Le macaron "Adhésion" (UX/UI)



🎯 Rôle UX/UI du Composant :

Incitation & Visibilité : Élément visuel flottant et stratégique pour identifier rapidement le statut d'adhérent et diriger vers le formulaire.

Respect de la Charte : Design parfaitement intégré à l'univers vintage des années 50 (teintes pastel et typographie dédiée).

Accessibilité Stricte : Contraste de couleurs optimisé et validé WCAG 2.1 AA pour garantir la lisibilité par tous les utilisateurs.

Maquettes & Démarche UX

Démarche UX & Écrans



Démarche & Prototypes

📱 **Mobile-First** : J'ai pensé la structure d'abord pour smartphone afin d'épurer le parcours utilisateur (clics larges, lecture verticale).

🔄 **Design Itératif** : J'ai opéré un passage successif de wireframes basse fidélité à des prototypes UI haute fidélité animés sous Figma.

💻 **Écrans Clés** :

- Accueil : J'ai conçu une bannière d'immersion avec typographie d'accroche.
- Boutique : J'ai structuré une grille responsive de cartes produits.
- Back-office : J'ai développé un dashboard optimisé pour la modération.

Identité Visuelle & Accessibilité



Identité & Inclusivité

🎨 **Palette Rétro Pop** : (Mets tes 4 petits carrés de couleur ici : Crème, Menthe, Corail, Charcoal)

🔤 **Typographies** :

- Titres : Pacifico (esprit néon rétro 1950s).

- Corps de texte : Montserrat (lisibilité optique).

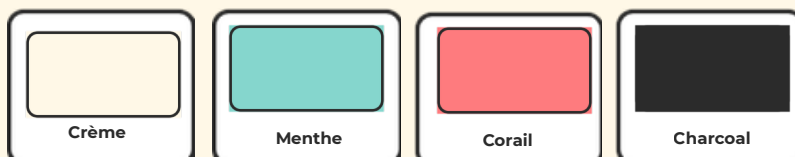
♿ **Accessibilité (WCAG 2.1 AA)** : J'ai validé des contrastes de couleurs élevés pour réduire la fatigue oculaire et garantir l'accès à tous.

Identité Rétro Bold

Un design nostalgique années 50 pensé pour l'inclusivité :

🔤 **Polices de caractères** : Pacifico pour les titres (esprit néon retro) et Montserrat pour le corps (lisibilité optique et confort de lecture).

♿ **Accessibilité WCAG 2.1 AA** : Contrastes de couleurs validés, lisibilité accrue pour réduire la fatigue oculaire.



Diners & Ronrons

"Là où les chats ronronnent, les idées pétillent et les bricoleurs réparent le monde."

Esthétique Rockabilly Pop Toulonnaise

Wireframe de la page d'accueil



✚ Structure UX : Définition des zones de navigation prioritaires (Header, Hero, Tuiles de contenu).

📱 Approche Mobile-First :

Épurement du contenu pour garantir une expérience fluide sur smartphone.

📐 Validation du Parcours : Test de la hiérarchie des informations avant l'intégration du design final.

Design UI Final - La Page d'Accueil



🎨 Design Système & Accessibilité :

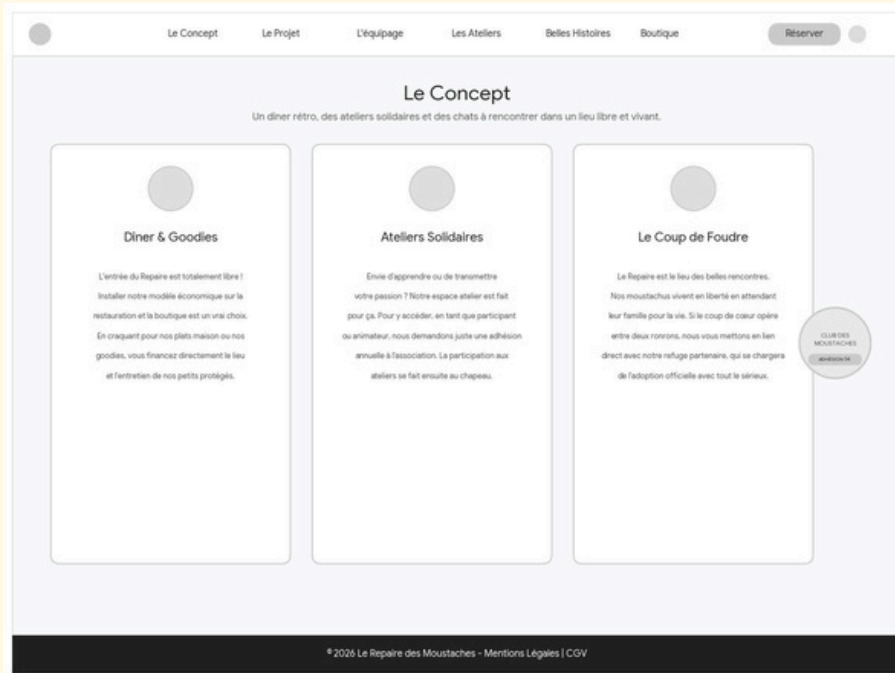
🖼️ Bannière d'accueil : Visuel immersif ambiance Diner 50's et appel à l'action (CTA) bien visible.

🎨 Cartes de navigation :

Utilisation des couleurs pastel contrastées (Corail, Menthe) et d'icônes thématiques.

⚙️ Composants : Intégration du badge flottant (avis/note) et footer structuré avec accès administration.

Wireframe - Page Le Concept (UX)



Architecture UX de la page Concept :

- Structure en 3 colonnes : Mise en valeur immédiate des 3 piliers de l'offre (Diner & Goodies, Ateliers Solidaires, Coup de Foudre).
- Hiérarchie de l'information : Titre accrocheur, sous-titre explicatif et pavés de texte courts pour une lecture fluide.
- Badges & Micro-interactions : Emplacement réservé au badge latéral d'adhésion pour inciter à la conversion.

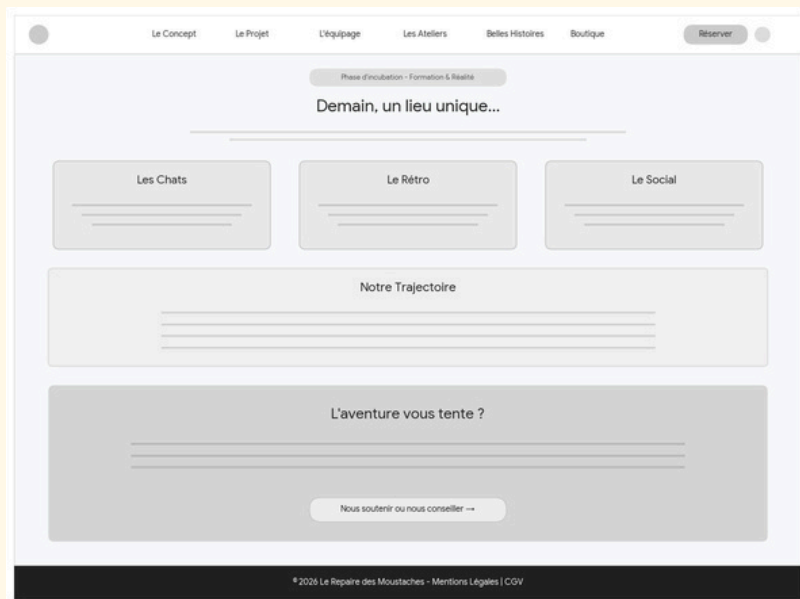
Design UI Final - Page « Le Concept »



Intégration Design & Composants :

- Harmonie graphique : Utilisation de la palette pastel (fond crème, bordures menthe/corail) respectant les standards de contraste WCAG.
- Illustration & Iconographie : Remplacement des placeholders par des illustrations vectorielles personnalisées (thématique féline/ateliers).
- Composants Réutilisables : Récupération de la navigation globale et du footer dynamique pour garantir une cohérence visuelle sur tout le site.

Wireframe - Page Le Projet (UX)



📌 Structure UX & Storytelling :
🚀 Accroche & Vision : Mise en avant du pitch initial ("Demain, un lieu unique...") pour poser la vision du tiers-lieu.

🐾 Piliers de valeurs : Découpage clair entre la cause animale (Les Chats), l'univers graphique (Le Rétro) et l'engagement (Le Social).

🚩 Call to Action (CTA) : Bloc dédié en bas de page pour engager la communauté ("L'aventure vous tente ?").

Design UI Final - Page Le Projet



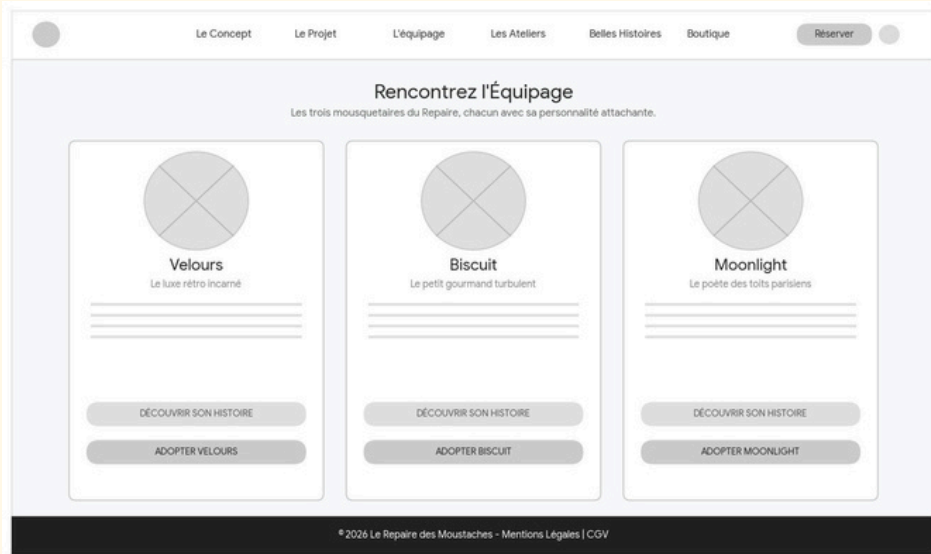
🎨 Habillage UI & Chronologie :

📁 Hiérarchie visuelle : Emploi de cartes colorées pastel (Menthe/Corail) avec icônes thématiques pour dynamiser la lecture.

🗺️ Section Trajectoire : Intégration d'une roadmap visuelle (dates et jalons clés du projet) facilitant la compréhension de l'avancement.

🌟 Bloc Engagement : Mise en avant du bouton d'action corail à fort contraste pour maximiser le taux de conversion/contact.

Wireframe – Page L'Équipage (UX)



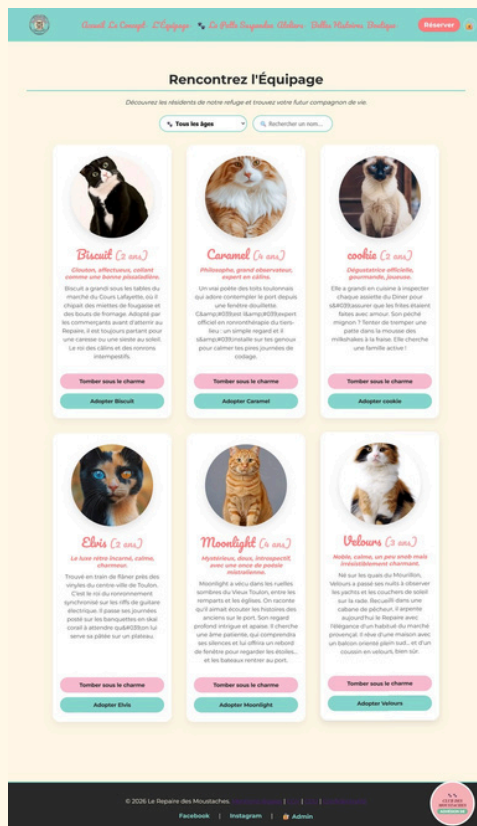
📌 Conception UX & Fiches Profils :

🐱 Présentation modulaire : Cartes profil uniformes pour présenter chaque chat (Velours, Biscuit, Moonlight) avec leur nom et trait de personnalité.

📖 Contenu immersif : Emplacements prévus pour la photo de profil, une courte description et l'histoire détaillée.

🔘 Double CTA : Boutons d'action distincts pour découvrir l'histoire complète ou initier une démarche d'adoption.

Design UI Final – Page L'Équipage



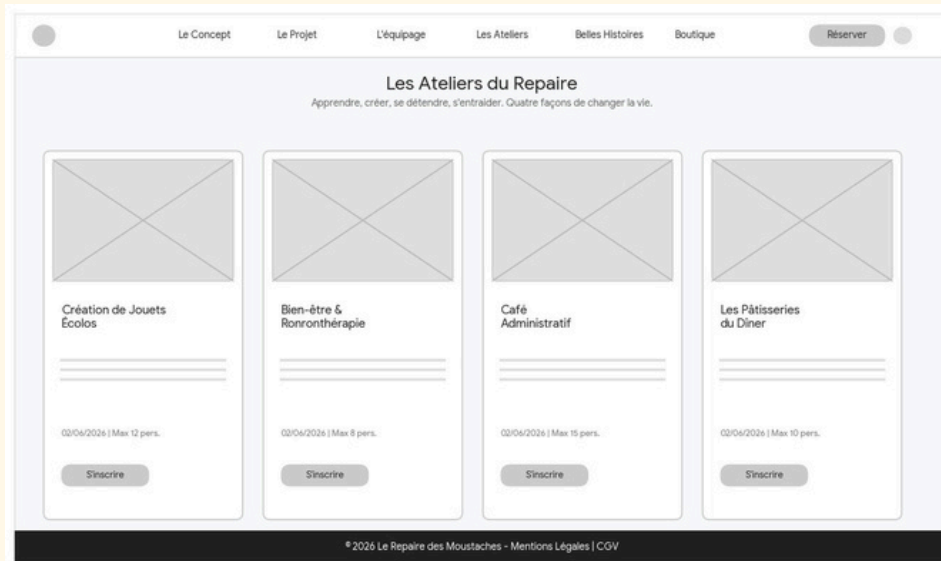
🎨 Rendu UI & Mise en valeur des résidents :

📸 Visuels engageants : Intégration de photos réelles dans des vignettes circulaires rétro avec bordures douces.

🔘 Design des boutons : Hiérarchie claire avec deux boutons distincts (Corail pour l'histoire, Menthe pour l'adoption).

📝 Micro-copywriting : Textes personnalisés et chaleureux pour renforcer le lien émotionnel et favoriser l'adoption responsable.

Wireframe - Page Les Ateliers (UX)



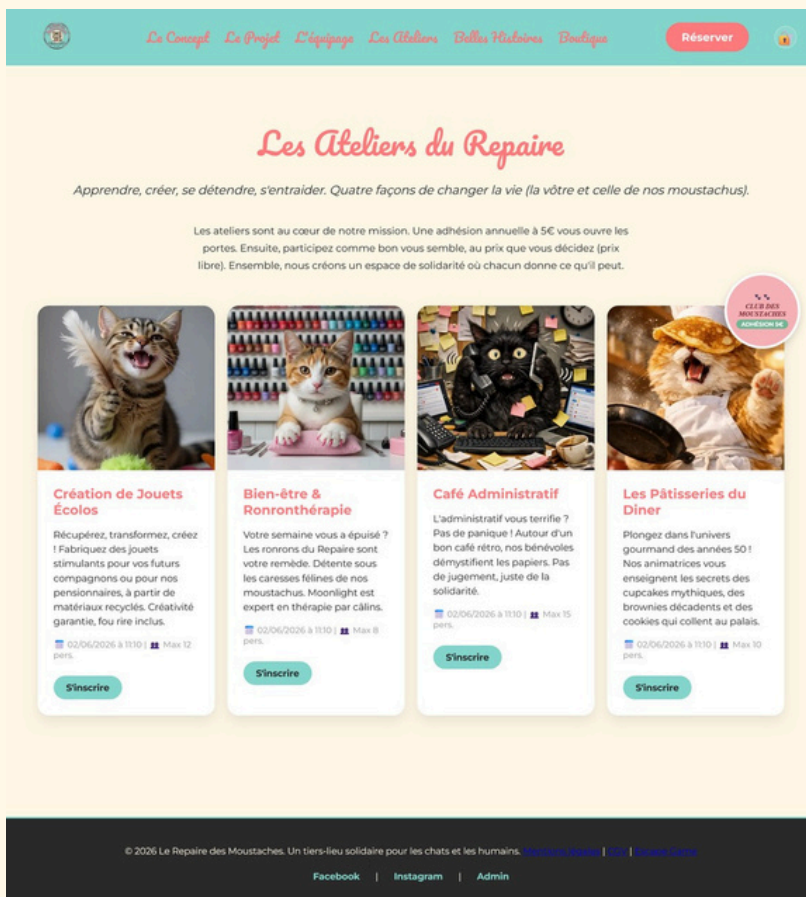
✚ Grille UX & Clarté de l'Offre :

☐ Layout en grille 4 colonnes : Présentation synthétique de l'éventail des activités proposées par le tiers-lieu.

📄 Standardisation des fiches : Structure uniforme intégrant image, titre, description, date/jauge et bouton d'action.

📅 Parcours de réservation : Emplacement dédié au bouton d'inscription pour inciter à la réservation rapide.

Design UI Final - Page « Les Ateliers »



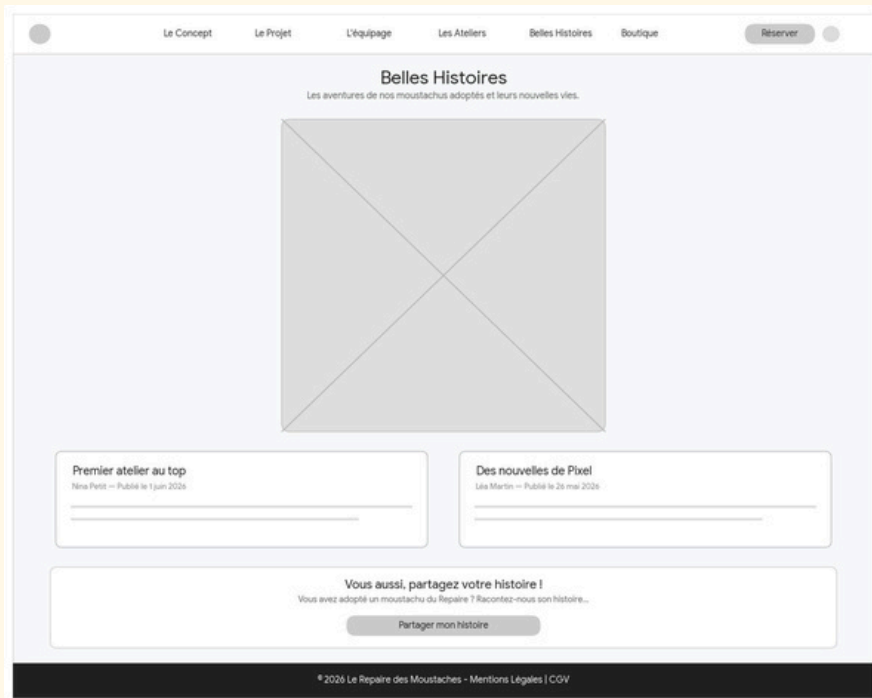
🎨 Rendu UI & Micro-informations :

🖼️ Visuels thématiques : Intégration de visuels chaleureux illustrant chaque type d'atelier (bricolage, détente, aide, cuisine).

📅 Métadonnées lisibles : Mise en avant claire des dates, horaires et jauges de places restantes (Max X pers.) en typographie contrastée.

🟢 Appel à l'action (CTA) : Boutons Menthe distinctifs pour inciter à l'inscription en un clic.

Wireframe - Page Belles Histoires (UX)



- 📌 Structure UX & Témoignages :
- 🖼️ Visuel Hero central :
Emplacement réservé à une grande image d'impact pour capter immédiatement l'attention du visiteur.
- 💬 Feed de cartes d'articles :
Présentation en colonnes des derniers témoignages d'adoptants avec auteur et date de publication.
- ✍️ Section Participation : Bloc d'incitation en bas de page pour inviter la communauté à soumettre son propre récit ("Partager mon histoire").

Design UI Final - Page Belles Histoires



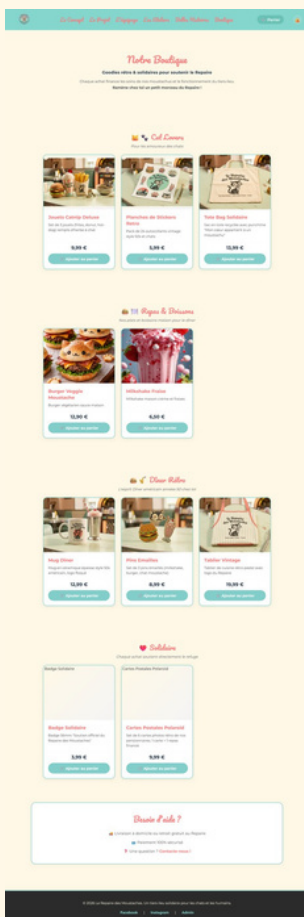
- 🎨 Rendu UI & Contenu Communautaire :
- 📸 Immersion visuelle :
Intégration d'un visuel dynamique et expressif mettant en scène la communauté féline du Repaire.
- 📝 Cartes de contenu aérées :
Typographie Pacifico pour les titres d'articles et fond blanc épuré avec coins arrondis pour une lisibilité optimale.
- 🟢 Bouton d'interaction : Bouton Menthe incitatif pour encourager l'envoi de nouveaux témoignages d'adoption.

Wireframe - Page Boutique (UX)



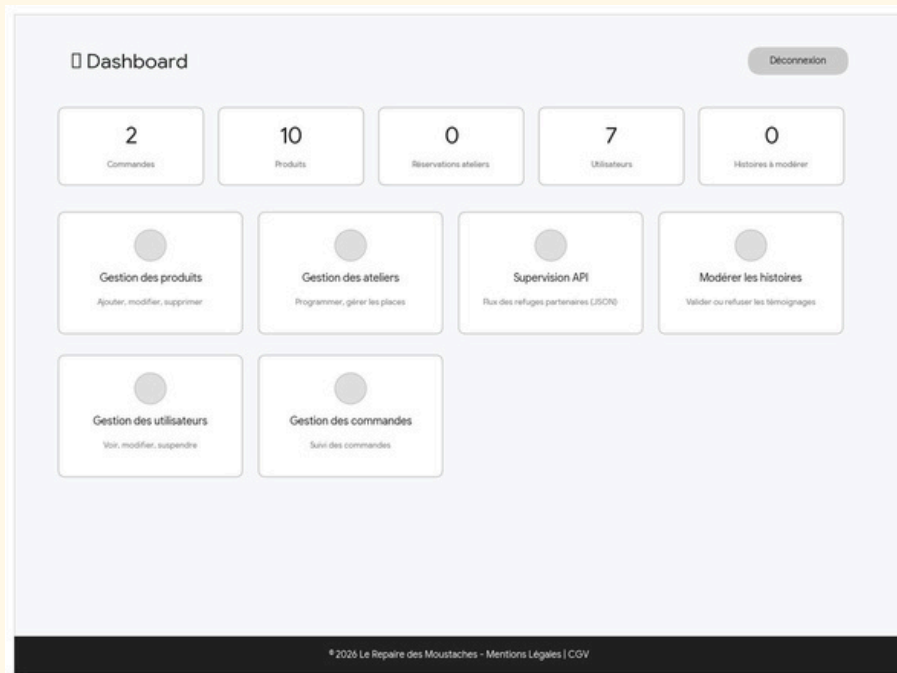
- 📌 Segmentation UX & E-commerce :
- 🛒 Organisation par catégories : Structuration claire de l'offre en 4 univers (Cat Lovers, Repas & Boissons, Diner Rétro, Solidaire).
- 🏷️ Fiches produits épurées : Affichage standardisé avec visuel, nom du produit, prix et bouton d'action direct.
- 🛒 Tunnel d'achat simplifié : Accès rapide au panier depuis l'en-tête pour un parcours utilisateur sans friction.

Design UI Final - Page Boutique



- 🎨 Rendu UI & Valorisation des Produits :
- 🍷 Identité visuelle gourmande : Photos haute définition mettant en valeur les plats du diner et les goodies solidaires.
- 🏷️ Codification des prix & CTA : Prix mis en valeur en typographie contrastée et boutons d'ajout au panier couleur Menthe.
- 🛡️ Réassurance client : Bloc d'aide et de réassurance intégré en bas de page (livraison, service client, adhésion).

Wireframe - Space Administration / Dashboard (UX)



📌 Architecture du Back-Office

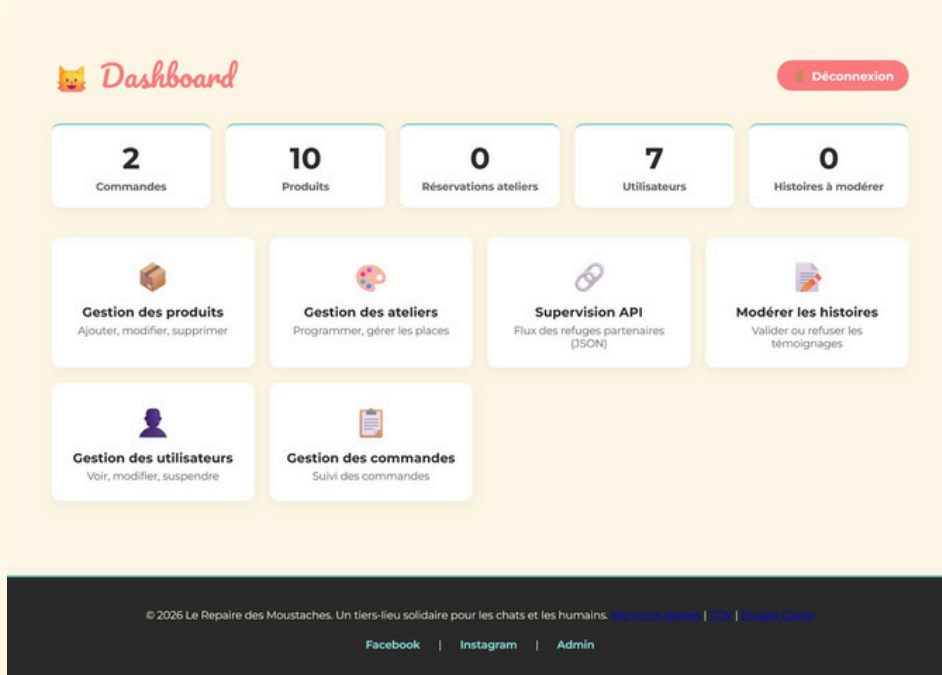
📊 KPIs & Indicateurs clés :

Vision globale immédiate (commandes, produits, inscriptions, utilisateurs, histoires en attente).

🗂️ Navigation modulaire : Cartes d'accès rapide vers les différents modules de gestion (Produits, Ateliers, API, Modération).

🔒 Sécurité & Accès : Bouton de déconnexion rapide et restriction d'accès réservée aux administrateurs.

Design UI Final - Space Administration / Dashboard



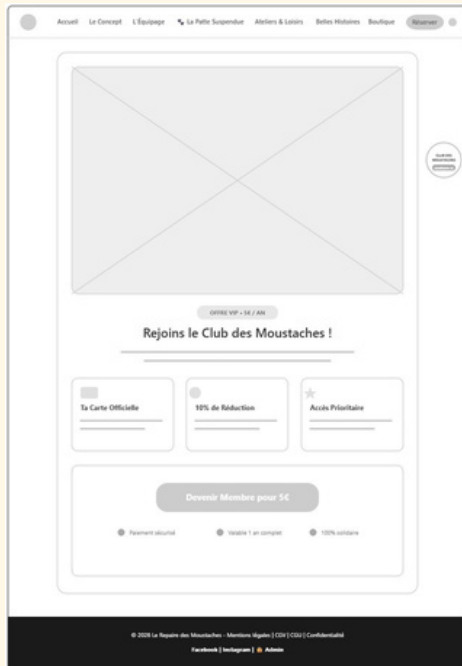
🎨 Interface Back-Office & Ergonomie

🎨 Cohérence graphique : Reprise des codes couleur du site (Coral/Pastel) pour un environnement d'administration moderne et agréable.

🧩 Iconographie métier : Utilisation d'icônes distinctives pour chaque fonctionnalité afin de faciliter la navigation de l'administrateur.

⚡ Gestion dynamique : Interface connectée à la base de données PDO pour une mise à jour en temps réel des indicateurs.

Wireframe - Page Adhésion / Soutenir l'association (UX)



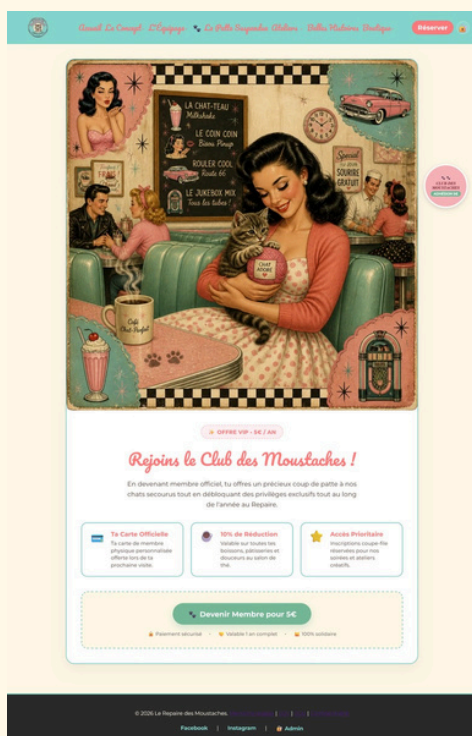
📌 Restructuration UX - Page Adhésion :

🖼️ Hiérarchie d'information centrée : Présentation de l'affiche rétro en grand format pour plonger le visiteur dans l'ambiance du salon de thé dès son arrivée.

📁 Grille de réassurance & avantages : Découpage explicite des 3 bénéfices clés (Carte physique, 10% de remise, Accès événements) sous forme de cartes d'impact.

🇫🇷 Conversion directe : Bouton d'action principal bien identifié (5€/an) accompagné de ses gages de confiance (sécurisé, 100% solidaire, 1 an).

Design UI Final - Page Adhésion / Soutenir l'association



🎨 Rendu UI & Univers Pin-up Rétro :

👩 Direction artistique affirmée : Illustration vintage style diner américain des années 50 renforçant l'identité du lieu.

📌 Puces d'avantages stylisées : Liste à puces avec icônes personnalisées pour rendre la lecture fluide et engageante.

🏆 Composants d'incitation : Intégration du macaron dynamique "Club des Moustaches" pour maximiser la conversion des sympathisants.

Wireframe - Page Douceur



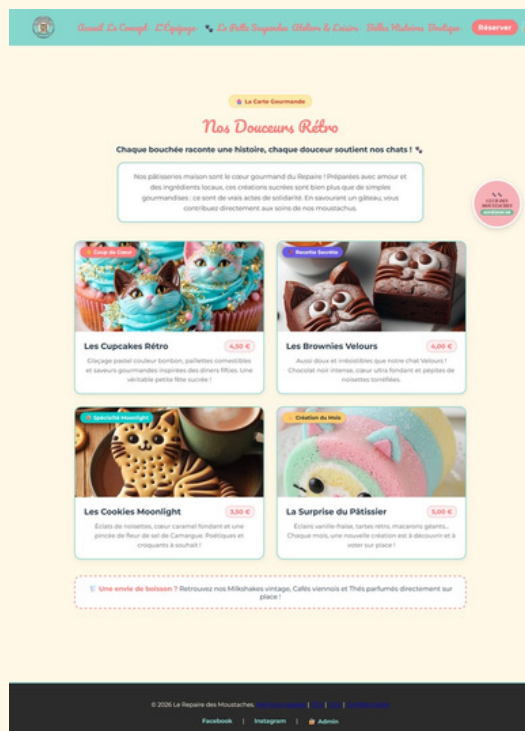
UX & Ergonomie - Page Douceurs Rétro :

Hiérarchie & Mise en avant : Valorisation des pâtisseries artisanales dès l'en-tête pour lier immédiatement plaisir gourmand et démarche solidaire du salon.

Catalogue structuré : Grille claire de fiches produits épurées avec badges d'attractivité (Coup de cœur, Recette secrète, Spécialité), visuel d'illustration, intitulé et tarif lisible.

Parcours fluide & Transversalité : Rappel discret des boissons et accès rapide au Club des Moustaches pour favoriser la conversion et le panier moyen.

Design UI final Page Douceur



UI & Direction Artistique - Page Douceur :

Identité visuelle & Ambiance : Déclinaison d'une palette pastel chaleureuse et rétro (tons crème, menthe et rose) renforçant le côté cocooning et gourmand du salon.

Mise en valeur des produits : Intégration de visuels haute définition avec des formes généreuses et arrondies, associées à des badges colorés pour captiver l'œil et donner envie.

Consistance & Lisibilité : Typographies thématiques soigneusement hiérarchisées pour une lecture fluide des titres, descriptifs et tarifs, tout en préservant la cohérence avec la charte globale du site.

Wireframe Page Repaire



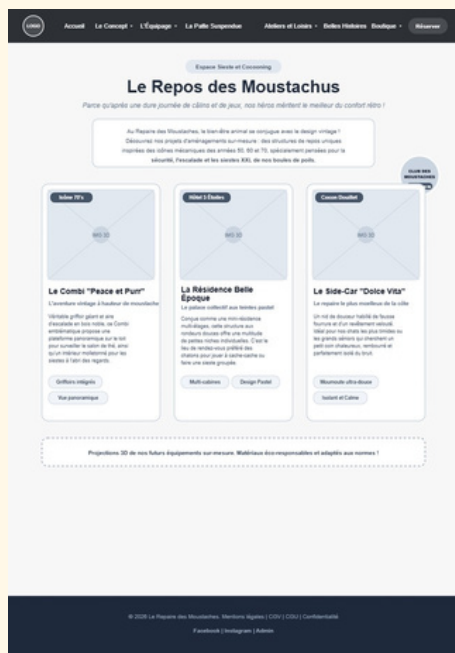
- 📌 Restructuration UX - Page Le Repaire :
- 🏛 Mise en valeur immersive : Emplacement stratégique accordé au visuel 3D du futur Diner/Salon de thé pour projeter immédiatement le visiteur dans l'atmosphère unique du lieu.
- 📖 Argumentaire en 2 temps : Structuration du storytelling à travers deux blocs distincts (L'Ambition conceptuelle/rétro vs L'Engagement éthique & solidaire).
- 🏆 Éléments transversaux : Intégration du macaron d'adhésion au Club des Moustaches en floating pour maintenir l'incitation au soutien associatif.

Design UI final page Repaire



- 🎨 UI & Direction Artistique - Page Le Repaire :
- 🎨 Univers visuel affirmé : Valorisation de la projection 3D pastel aux teintes diner vintage (menthe et rose bonbon), parfaitement intégrée dans le fond crème chaleureux.
- 📖 Storytelling & Lisibilité : Structuration sur deux colonnes équilibrées associant la lisibilité des typographies et la douceur des bordures arrondies.
- ✅ Cohérence globale : Reprise du bandeau de navigation turquoise avec l'action "Réserver" en surbrillance corail pour maximiser la conversion.

Wireframe Page Repos des Moustachus



📌 Restructuration UX - Page Le Repos des Moustachus :

🐾 Mise en valeur de l'aménagement félin : Présentation des équipements rétro sur-mesure sous forme de catalogue pour sensibiliser les visiteurs au bien-être animal.

📐 Cartes thématiques à 3 colonnes : Structuration claire avec visuel 3D, badges de catégorie (Icône 70's, Hôtel 5 Étoiles, Cocon Douillet), descriptif détaillé et puces de fonctionnalités clés.

🌿 Éléments de réassurance : Intégration d'un bandeau d'information précisant l'usage de matériaux éco-responsables et adaptés aux normes sanitaires et félines.

Design UI Page Repos des Moustachus



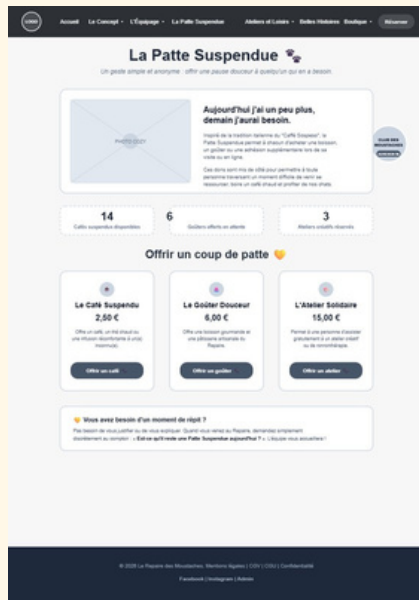
🎨 UI & Direction Artistique - Page Le Repos des Moustachus :

🚗 Intégration 3D & Design Rétro : Harmonisation des modélisations 3D pastel (teintes menthe, rose poudré et orangé vintage) dans une mise en page fluide et moderne.

✨ Hiérarchie visuelle douce : Utilisation de polices arrondies et conviviales associées à des pastilles colorées pour identifier facilement les atouts de chaque mobilier.

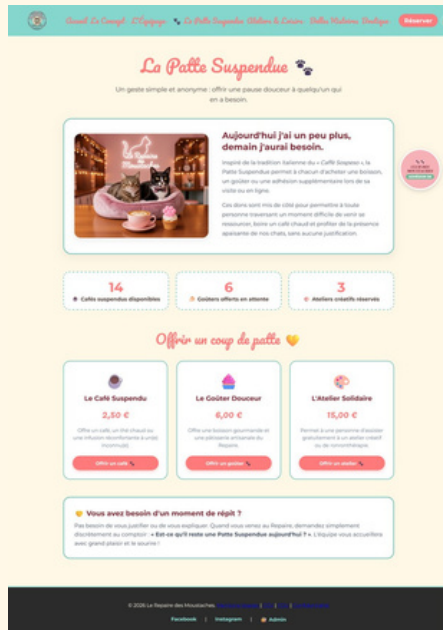
🎯 Cohérence d'ensemble : Conservation de l'en-tête turquoise, du fond crème et du macaron flottant Club des Moustaches pour maintenir l'identité visuelle globale du site.

Wireframe Page Patte Suspendue



- 📌 Restructuration UX - Page La Patte Suspendue :
- 👉 Valorisation de la démarche solidaire : Mise en avant du concept inspiré du « Caffè Sospeso » pour encourager la bienveillance et le don anonyme.
- 📊 Transparence et compteurs en direct : Intégration de 3 blocs chiffrés (Cafés, Goûters, Ateliers disponibles) pour matérialiser l'impact immédiat des dons.
- 💖 Parcours bénéficiaire bienveillant : Ajout d'une section explicative en bas de page pour rassurer les bénéficiaires et lever toute barrière à la demande discrète au comptoir.

Design UI final Page Patte Suspendue



- 🎨 UI & Direction Artistique - Page La Patte Suspendue :
- ☕ Ambiance chaleureuse et réconfortante : Utilisation d'une typographie manuscrite douce (« Offrir un coup de patte ») alliée à des tons pastel corail et dorés.
- 💳 Clarté de la grille d'achat solidaire : Cartes d'action à 3 paliers de prix avec icônes illustrées (Café, Goûter, Atelier) et boutons d'appel à l'action explicites.
- 🔄 Cohérence visuelle globale : Alignement sur le header turquoise, le fond crème et la présence du macaron flottant Club des Moustaches.

Wireframe Page Faq



📌 Restructuration UX - Page FAQ / F.A.Q. :

🐱 Hiérarchie de l'information : Mise en valeur visuelle de la mascotte centrale pour créer de l'engagement dès l'arrivée sur la page.

📁 Système d'accordéon interactif : Regroupement des questions récurrentes dans une carte épurée avec pictogrammes « + » pour clarifier le parcours et éviter de surcharger l'écran.

🎯 Réponses ciblées aux besoins : Traitement direct des interrogations sur la sécurité (venir avec un animal), l'accueil des enfants, l'adhésion et le lieu physique à Toulon.

Design UI final Page Faq



🎨 UI & Direction Artistique - Page FAQ / F.A.Q. :

🐱 Illustratif et ludique : Utilisation de la mascotte chat noir rétro aux yeux expressifs avec un ton bienveillant (« Nos ronrons ont la réponse »).

✍️ Design aéré et lisible : Palette crème chaleureuse pour le fond, typographie corail manuscrite en titre et typographie sombre et nette pour les questions.

🧩 Cohérence multi-pages : Maintien du header turquoise, du macaron Club des Moustaches en bas de page et du footer épuré.

Wireframe Page Contact

The wireframe shows a contact page with a dark header containing navigation links: Logo, Accueil, Le Concept, L'Équipage, La Paille Suspendue, Ateliers et Loisirs, Belles Histoires, Boutique, and Réserver. The main heading is 'Une question ? Une idée ?' with a heart icon. Below it, a subtext reads 'Toute l'équipe est à votre écoute pour échanger sur le projet du Repaire.' The page is divided into two columns. The left column contains a section 'Tiers-Lieu en Préparation' with the heading 'Où nous trouver ?' and text about the location in Toulon. Below this is a section 'Parlons-en !' with a list of topics: 'Des questions sur l'adoption', 'Proposer un atelier créatif', and 'Proposer un partenariat ou de l'aide'. The right column contains a contact form with fields for 'Votre nom & prénom', 'Votre adresse e-mail', 'Sujet de votre message' (with a dropdown menu), and 'Votre message'. A 'Envoyer le message' button is at the bottom. A circular logo for 'CLUB DES MOUSTACHES' is on the right side of the form. The footer includes copyright information and social media links for Facebook, Instagram, and Admin.

UX & Ergonomie - Page Contact & Échanges :

- Clarification des objectifs : Organisation du contenu en deux colonnes distinctes pour séparer l'information institutionnelle (Localisation & Ambitions à Toulon) du canal d'interaction (Formulaire de contact).
- Simplification du parcours : Formulaire épuré restreint aux champs essentiels (Nom, Email, Objet, Message) avec menu déroulant pour orienter la demande et accélérer le traitement.
- Multi-canaux & Transversalité : Mise en avant directe de l'e-mail de contact, de la FAQ ("Nos Ronrons") et maintien du macaron d'adhésion au Club des Moustaches en floating pour stimuler l'engagement.

Design UI final Page Contact

The final UI design features a light teal header with navigation links: Accueil, Le Concept, L'Équipage, La Paille Suspendue, Ateliers et Loisirs, Belles Histoires, Boutique, and Réserver. The main heading is 'Une question ? Une idée ?' with a heart icon. Below it, a subtext reads 'Toute l'équipe est à votre écoute pour échanger sur le projet du Repaire.' The page is divided into two columns. The left column contains a section 'Tiers-Lieu en Préparation' with the heading 'Où nous trouver ?' and text about the location in Toulon. Below this is a section 'Parlons-en !' with a list of topics: 'Des questions sur l'adoption', 'Proposer un atelier créatif', and 'Proposer un partenariat ou de l'aide'. The right column contains a contact form with fields for 'Votre nom & prénom', 'Votre adresse e-mail', 'Sujet de votre message' (with a dropdown menu), and 'Votre message'. A 'Envoyer le message' button is at the bottom. A circular logo for 'CLUB DES MOUSTACHES' is on the right side of the form. The footer includes copyright information and social media links for Facebook, Instagram, and Admin.

UI & Direction Artistique - Page Contact

Charte graphique : Liseré corail/rose poudré sur fond crème pour un rendu chaleureux et accueillant.

Ergonomie & Lisibilité : Champs arrondis très lisibles et bouton d'action (CTA) corail avec icône de patte.

Dynamisme : Superposition fluide du macaron "Club des Moustaches" pour apporter du relief à la composition.

Wireframe Page Mentions Légales



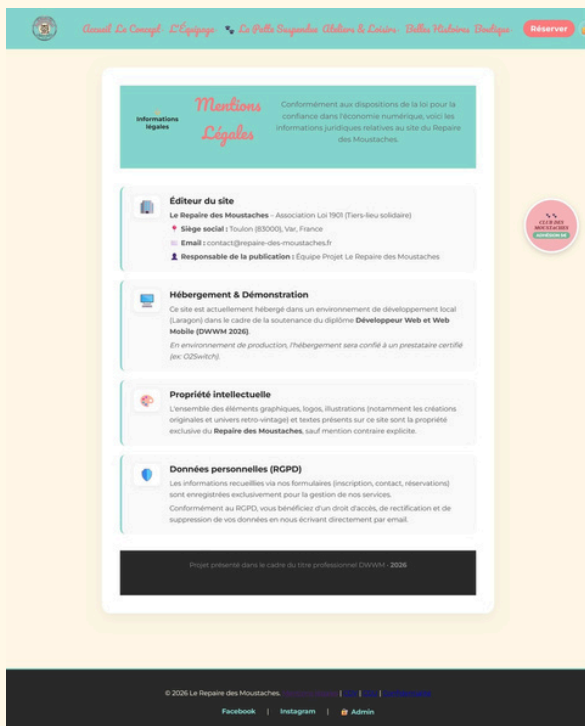
📌 UX & Ergonomie - Page Mentions Légales :

📄 Lisibilité & Structuration : Organisation des données réglementaires sous forme de blocs d'information distincts (Cartouches) équipés de pictogrammes pour faciliter la scannabilité rapide.

🏛️ Transparence & Pédagogie : Identification claire de l'éditeur du site (Association à Toulon), des règles d'hébergement et du cadre académique (Titre professionnel DWWM).

🛡️ Conformité & Droits utilisateur : Accent mis sur la protection des données (RGPD) avec rappel explicite du droit d'accès, de rectification et de suppression par simple demande email.

Design UI final Page Mentions Légales



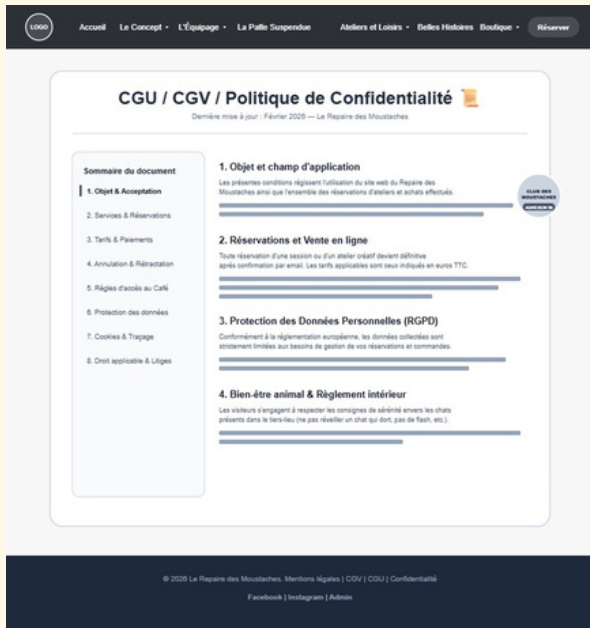
🎨 UI & Direction Artistique - Page Mentions Légales :

🇫🇷 En-tête thématique : Utilisation d'un bandeau menthe/turquoise rétro affirmé pour introduire les informations juridiques avec douceur et cohérence visuelle.

📦 Design modulaire épuré : Intégration de cartes blanches à bordures fines pastel, dotées de puces illustrées colorées (Éditeur, Hébergement, Propriété intellectuelle, RGPD).

🎨 Continuité de la charte : Maintien du fond crème d'arrière-plan, du macaron Club des Moustaches en floating à droite et d'une bannière de pied de page sombre pour fermer élégamment le conteneur central.

Template - Pages Légales (CGU / CGV / Confidentialité)

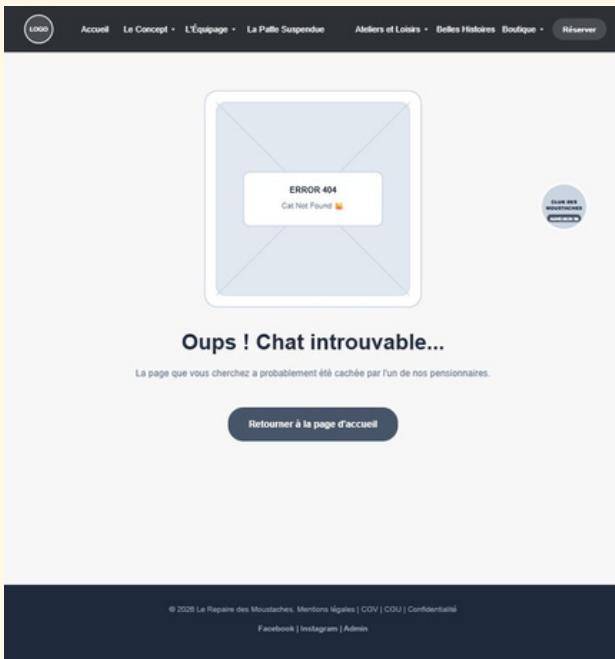


- 📌 Mutualisation du Template - Pages Légales & Réglementaires :
- 🧩 Approche Modulaire : Layout unique (Master Template) partagé (CGU, CGV, Confidentialité) pour assurer la cohérence visuelle et faciliter la maintenance.
- 📖 Navigation Facilitée : Sommaire à ancres interactif dans la colonne de gauche pour un accès direct aux clauses sans scroller.
- 🐾 Rassurance & Transparence : Présentation aérée du texte juridique et rappel du règlement intérieur dédié au bien-être animal dans le tiers-lieu.

Informations Réglementaires



Wireframe Page 404



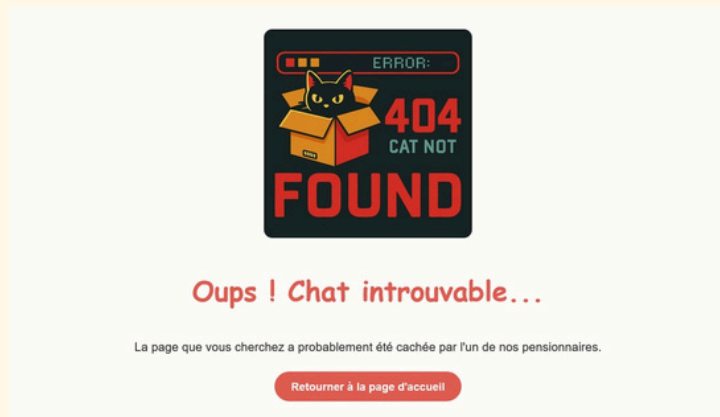
📌 UX & Gestion des Erreurs - Page 404

🐱 Traitement de la frustration : Transformation de l'erreur en expérience positive via un ton humoristique et bienveillant (« Chat introuvable »).

🧭 Guidage & Redirection : Bouton d'action principal (CTA) vers l'accueil pour réduire le taux de rebond et relancer le parcours.

🔗 Continuité de navigation : Maintien du Header et du Footer pour permettre de repartir vers n'importe quelle section du site.

Design UI final Page 404



🎨 UI & Storytelling Visuel - Page 404 :

📦 Illustration rétro & thématique : Visuel vintage sur-mesure d'un chat noir sortant d'un carton (« 404 Cat Not Found »).

🔪 Micro-copie engageante : Titre corail arrondi (« Oups ! Chat introuvable... ») et métaphore ludique (« cachée par l'un de nos pensionnaires »).

🔴 Feedback visuel clair : Bouton d'action rouge corail bien détaché du fond crème pour rendre le retour à l'accueil évident.

Intégration Front-End & Identité Visuelle

« **Ce que nous sommes:**

50% Rockabilly, 50% Ronronthérapie, 100% Engagés.

🎨 Identité Visuelle & Performances Web

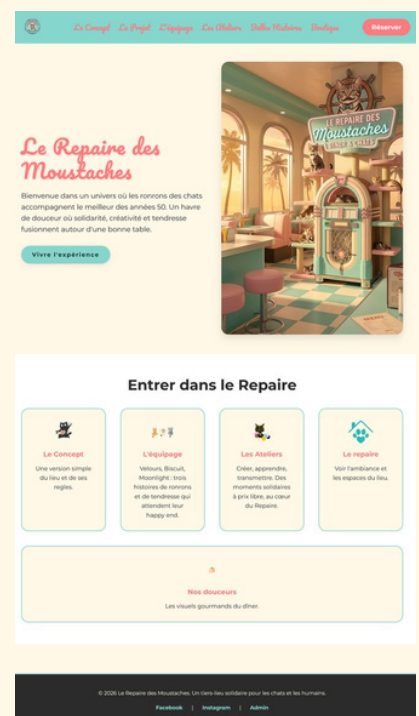
- 🖨️ Univers 50s : Teintes pastel, typographies Pacifico & Montserrat, ambiances néons pour créer un refuge émotionnel.
- ⚙️ Architecture CSS : Variables globales (:root), effets hover et ombrages épurés pour alléger le code et faciliter la maintenance.
- ⚡ Optimisation Assets : Compression poussée des images et polices pour un chargement ultra-rapide.

« Une architecture modulaire native et un code PHP aussi carré qu'un riff de guitare. »

💻 Technologies Front-End & Intégration :

💻 Intégration Sémantique & Technique

- 🏗️ Structure Sémantique : HTML5 épuré et accessible (<header>, <main>, <footer>, <section>) respectant fidèlement le wireframe d'origine.
- 📐 Mise en page Moderne : Usage exclusif de CSS3 natif (Flexbox & Grid) pour un affichage parfaitement fluide et responsive.
- 🌿 Sobriété Technique : Choix du Vanilla CSS sans framework lourd (ni Bootstrap, ni Tailwind) pour un code sur-mesure, léger et à faible empreinte carbone.



Preuves d'Accessibilité (WCAG 2.1 AA)

Navigation Clavier & Focus

L'ensemble des interactions (liens, boutons, inputs) est accessible au clavier. L'état de :focus n'est pas masqué mais renforcé visuellement par un contour contrasté, assurant une parfaite lisibilité pour les utilisateurs d'outils d'assistance.

Sémantique & Attributs ARIA

- Attributs alt d'illustrations obligatoires et descriptifs pour les lecteurs d'écran (ex: alt="Chat noir à lunettes").
- Attributs aria-label sur les boutons asynchrones d'ajout au panier.

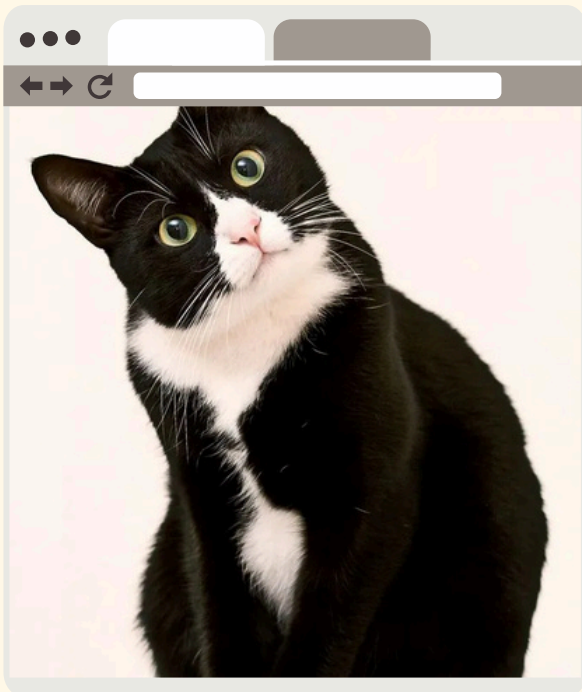
SIMULÉ : FOCUS CLAVIER ACTIF

Bouton d'Adoption Responsable

Appuyer sur [TAB] cible cet élément. L'outline personnalisé de 3px assure que l'utilisateur sait toujours où se trouve le pointeur clavier.

Adopter Velours →

✅ WAVE Tool validation : 0 Erreurs de contraste, structure d'en-tête (h1-h6) sémantiquement logique et continue.



```
<!-- Exemple d'accessibilité WCAG 2.1 AA pour la fiche d'un félin -->
<article class="cat-card">
  
  <div class="cat-info">
    <h3>Biscuit</h3>
    <button aria-label="Réserver un créneau pour rencontrer Biscuit">
      Parrainer Biscuit
    </button>
  </div>
</article>
```


Arborescence du Code & Routage

Architecture & Point d'Entrée

Mon choix d'architecture : J'ai conçu une arborescence structurée où `public/index.php` sert de point d'entrée unique. J'ai confié la gestion de l'accès aux pages directement au serveur Web, tandis que chaque script PHP que j'ai développé initialise la session et inclut les composants requis.

```
REPAIRE_DES_MOUSTACHES/
├── config/
│   └── database.php          # Connexion BDD PDO (Singleton)
├── database/
│   └── schema.sql           # Scripts d'export & Schéma SQL
├── docs/
│   └── lighthouse.html      # Rapports d'audit & Métriques
├── includes/
│   ├── header.php          # Composants HTML/PHP réutilisables
│   └── footer.php          # Principe DRY
├── public/                  # Web Root (Seul dossier accessible)
│   ├── admin/              # Espace d'administration (Sessions)
│   ├── css/                # Feuilles de style
│   ├── js/                 # Scripts JS client
│   ├── images/             # Médias statiques & Uploads
│   └── index.php            # Point d'entrée principal / Routeur
└── README.md               # Documentation d'installation
```

L'Environnement Technique

Serveur Local & IDE



J'ai configuré un environnement de développement isolé et sélectionné un éditeur de code avancé.

Laragon

VS Code

Prettier

Gestion de Version



J'ai assuré le suivi de mes modifications et le déploiement de mon code source à distance.

Git CLI

GitHub

Open Source

Back-End & Persistance



J'ai développé un moteur applicatif robuste appuyé sur mon propre système de gestion de données.

PHP 8.2

MySQL 8.0

PDO

Design & UI/UX



J'ai réalisé la conception graphique et la création de l'ensemble de mes maquettes fonctionnelles.

Canva

Figma

Wireframing



Sécurisation & Mesures OWASP



Anti-Injection SQL :

J'ai séparé les requêtes SQL des données utilisateurs via PDO::prepare().



Protection CSRF & Sessions :

J'ai sécurisé les formulaires et verrouillé les sessions (hash_equals(), session_regenerate_id()).



Protection XSS :

J'ai neutralisé l'injection de scripts malveillants dans l'affichage HTML via htmlspecialchars().

Preuves de Sécurisation (Code PHP)

Database.php — Requetes préparées

```
// 1. Requête préparée complexe (Anti-injection SQL)
public function registerReservation($userId, $atelierId, $places) {
    $sql = "INSERT INTO reservations_ateliers (id_utilisateur, id_atelier, places_reservees,
    date_inscription)
    VALUES (:user, :atelier, :places, NOW())";

    $stmt = $this->db->prepare($sql);
    $stmt->execute([
        ':user' => $userId,
        ':atelier' => $atelierId,
        ':places' => $places
    ]);
    return $stmt->rowCount() > 0;
}
```

BlocCode2:security.php—Validation CSRF

```
// 2. Jeton CSRF (Validation à temps constant)
function validateCSRF($token) {
    if (!isset($_SESSION['csrf_token']) || empty($token)) {
        return false;
    }

    // Protection contre les attaques temporelles (Timing attack)
    return hash_equals($_SESSION['csrf_token'], $token);
}

// Génération sécurisée du jeton
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}
```

Contrôle MIME / finfo (Téléversement)

```
public function uploadCatImage($file) {
    // 1. Validation de l'upload
    if ($file['error'] !== UPLOAD_ERR_OK) {
        throw new Exception("Erreur lors de l'upload.");
    }

    // 2. Contrôle binaire du type MIME réel (finfo)
    $finfo = new finfo(FILEINFO_MIME_TYPE);
    $mimeType = $finfo->file($file['tmp_name']);

    $allowedMimeTypes = [
        'image/jpeg' => 'jpg',
        'image/png' => 'png',
        'image/webp' => 'webp'
    ];

    if (array_key_exists($mimeType, $allowedMimeTypes)) {
        throw new Exception("Format non autorisé (Seuls JPG, PNG et WebP sont acceptés).");
    }

    // 3. Renommage aléatoire sécurisé & extension forcée
    $extension = $allowedMimeTypes[$mimeType];
    $safeName = bin2hex(random_bytes(10)) . '-' . $extension;
    $destination = "../public/images/uploads/" . $safeName;

    // 4. Déplacement sécurisé
    move_uploaded_file($file['tmp_name'], $destination);
    return $safeName;
}
```

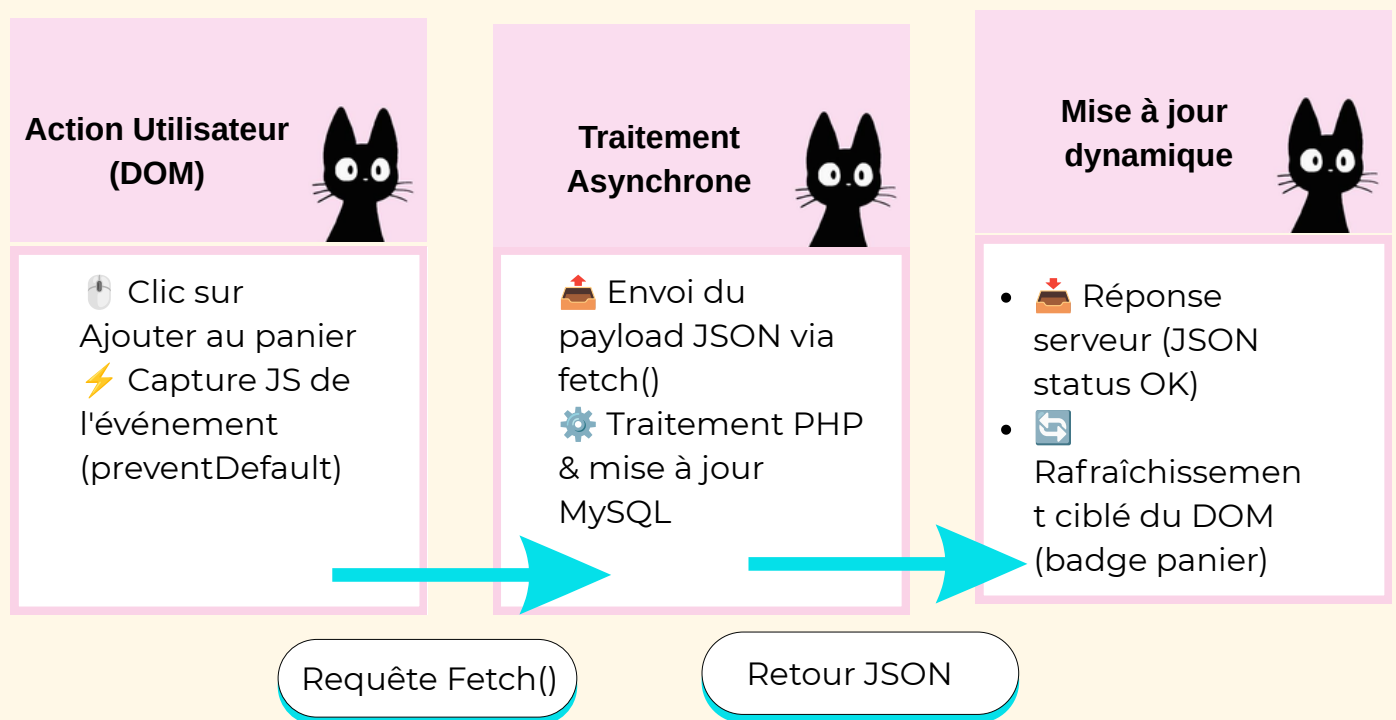
💡 Mon Analyse Sécurité :

J'ai utilisé hash_equals() pour prévenir les fuites d'informations par mesure du temps de réponse (timing attacks) et les requêtes préparées PDO pour bloquer toute injection SQL.

Architecture Technique

Requêtes Asynchrones (API Fetch)

"Optimisation de l'expérience utilisateur : Traitement des données en arrière-plan sans rechargement de la page."



```
// Envoi des données au serveur en arrière-plan
fetch('/api/cart/add.php', {
  method: 'POST',
  headers: { 'Content-Type': 'application/json' },
  body: JSON.stringify({ product_id: 12, quantity: 1 })
})
.then(response => response.json())
.then(data => {
  // Mise à jour dynamique du DOM sans recharger la page
  document.querySelector('.cart-badge').textContent = data.totalQuantity;
});
```

⚡ Fluidité UX

📊 Performance JSON

🔒 Sécurité PHP

Rapport de Performance Lighthouse

Audit & Métriques



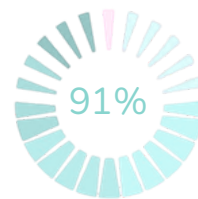
Performances



Accessibilité



Bonnes Pratiques



SEO

Optimisations d'Affichage -

Vitesse & Poids des Pages

 Formats Modernes :
Conversion dynamique des images au format WebP avec solution de secours (fallback).

 Gain de Poids : Réduction du chargement initial de la page jusqu'à 70 %.

 Chargement Différé :
Implémentation du Lazy-Loading natif pour optimiser les performances d'affichage.

Éco-conception Web - Éco-Conception Logicielle

 Requêtes SQL optimisées :
Jointures ciblées pour réduire la charge serveur et le temps de réponse.

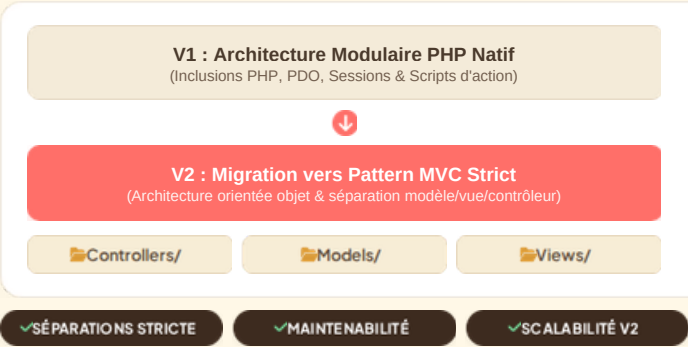
 Structure HTML légère : Code sémantique, propre et débarrassé de tout élément inutile.

 Zero Framework lourd :
Absence d'outils superflus (ex: pas de jQuery) pour conserver un script ultra-léger.

 Sobriété d'Assets : Limitation stricte des dépendances et ressources externes non essentielles.

Évolutions & Roadmap V2

Evolution de l'Architecture



Comparatif & Incohérences Régliées

Composant	V1 (Application Actuelle)	V2 (Roadmap Cible)
Architecture	PHP 8.2 Natif Modulaire (Includes / Actions)	Pattern MVC Strict (ex: Framework)
Accès Données	Requêtes PDO & Requêtes préparées	ORM (ex: Doctrine) & Migrations
Interactivité	Formulaires + Échanges AJAX / Fetch	API RESTful + Composants Dynamiques
Paieement	Validation locale panier / adhésion	Intégration API Stripe / Paypal

« Nouvelles Fonctionnalités Métier V2 »

- 🏠 Paiement en ligne sécurisé : Intégration de l'API Stripe / PayPal pour les réservations de créneaux et la boutique.
- ✉️ Notifications automatisées : Envoi d'emails de confirmation et rappels de réservation de créneau via PHPMailer ou SendGrid.
- 📱 Application Mobile PWA : Transformation en Progressive Web App pour permettre la réservation hors-ligne et les notifications Push.

🎯 Objectif V2 : Passer d'une architecture modulaire PHP robuste à un framework complet (Symfony / Laravel) pour accompagner la croissance du café.

Organisation en 3 dossiers



/config

CONFIGURATION & SÉCURITÉ

Stockage hors zone publique des éléments de configuration critique de l'application.

- ✓ Connexion BDD globale sécurisée par **PDO**
- ✓ Variables d'environnement (.env)
- ✓ Constantes applicatives globales



/includes

GABARITS & HELPERS

Modules réutilisables et fonctions utilitaires de sécurité partagés sur le site.

- ✓ Éléments réutilisables (header, footer)
- ✓ Fonctions de protection globale (**Anti-XSS**)
- ✓ Helpers d'échappement et sanitisation



/public

RACINE WEB (DOCUMENT ROOT)

Seul dossier accessible publiquement via le navigateur.

 **Front-Office** Vitrine, catalogue boutique, réservation d'ateliers

 **/admin (Back-office)** Espace d'administration hermétique et sécurisé



« J'ai structuré l'application avec la racine web pointant sur /public. Les dossiers /config et /includes sont placés au-dessus de cette racine pour garantir qu'aucun fichier de configuration sensible ne soit accessible directement via le navigateur. Le dossier /admin est quant à lui sécurisé au sein de la zone publique par des contrôles d'accès et de sessions stricts. »

Base Relationnelle MySQL



1. Utilisateurs

Tables : utilisateurs, roles, logs_activite.



2. Gestion des Félin's

Tables : pensionnaires, refuges, belles_histoires.



3. Boutique & Cmds

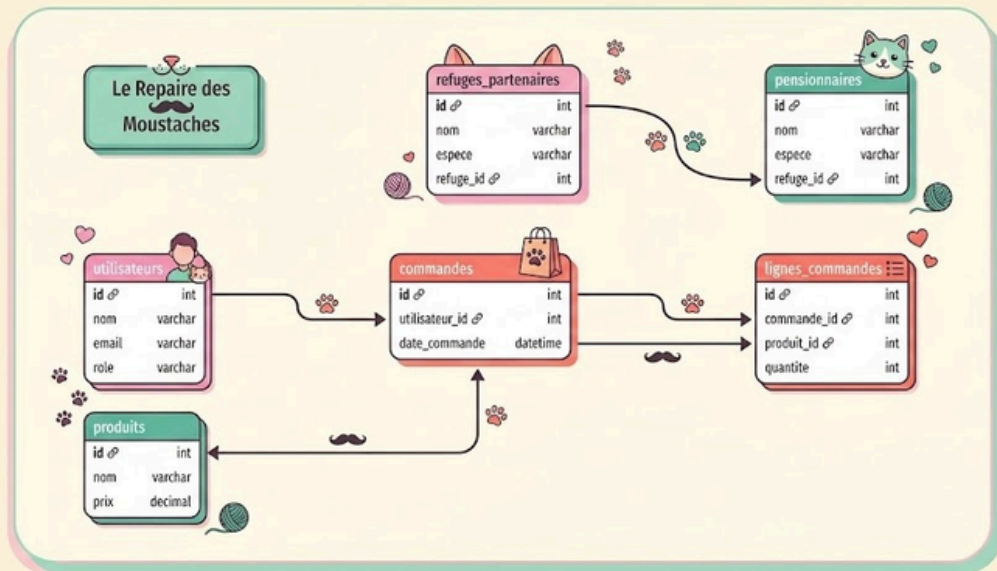
Tables : produits, categories, commandes, lignes_commandes.



4. Ateliers & Solidarité

Tables : ateliers, reservations_ateliers, adhesions.

Modélisation Conceptuelle des Données (MCD) - Cœur Métier



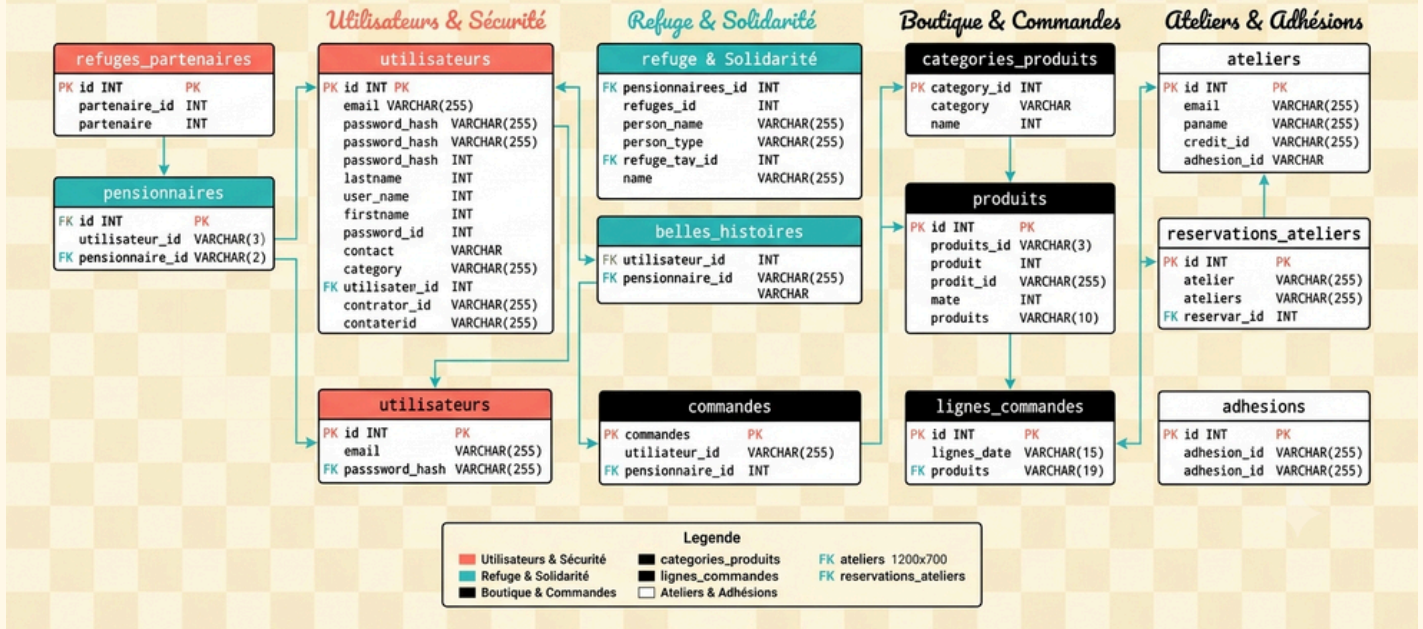
🔄 Architecture & Flux de Données - Diagramme d'Interactions

- 👤 **Gestion des Utilisateurs** : Inscriptions, authentification et administration des profils clients & membres.
- 🐾 **Cycle des Adoptions** : Suivi des fiches pensionnaires, demandes de réservation et dossiers d'adoption.
- 🛒 **Boutique & Commandes** : Gestion du catalogue produit, validation du panier et traitement des paiements.

Schéma relationnel des données (mld)

□ Schéma Relationnel — 13 Tables

Le Repaire des Moustaches — Base de données normalisée



Respect des Formes Normales (1NF, 2NF, 3NF)
Absence de redondance et atomisation des données.



Contraintes d'Intégrité Référentielle
Clés primaires (PK), clés étrangères (FK) et règles ON DELETE CASCADE.



Gestion des Relations Many-to-Many (\$N:M\$)
Utilisation de tables de liaison dédiées pour les inscriptions, le panier et les adhésions.



```
CREATE TABLE reservations_ateliers (
  user_id INT NOT NULL,
  atelier_id INT NOT NULL,
  FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE,
  PRIMARY KEY (user_id, atelier_id)
);
```



Structure et modèles de base de données

1. Liste des Tables Principales

- **utilisateurs** : (id, nom, email, mot_de_passe, role, created_at)
- **adhesions** : (id, utilisateur_id, formule_id, date_debut, date_fin, statut)
- **commandes** : (id, utilisateur_id, total, statut, created_at)
- **lignes_commande** : (id, commande_id, produit_id, qte, prix_unitaire)
- **produits** : (id, nom, description, prix, stock, categorie_id)
- **categories** : (id, libelle)
- **pensionnaires** : (id, nom, espece, age, description, photo)
- **equipe** : (id, nom, role, bio, photo)
- **privatisations** : (id, utilisateur_id, date, nb_personnes, statut)
- **formules** : (id, libelle, prix, duree_mois)
- **avis** : (id, utilisateur_id, note, commentaire, created_at)
- **contacts** : (id, nom, email, message, lu)
- **sessions_admin** : (id, admin_id, token, expire_at)

2. Relations Clés (Clés Étrangères)

- adhesions.utilisateur_id → utilisateurs.id
- commandes.utilisateur_id → utilisateurs.id
- lignes_commande.commande_id → commandes.id
- lignes_commande.produit_id → produits.id

3. Contraintes d'Intégrité Implémentées

- **Validation des notes** : CHECK (note BETWEEN 1 AND 5) sur la table avis.
- **Intégrité financière** : CHECK (total > 0) sur la table commandes.
- **Unicité des comptes** : UNIQUE (email) sur la table utilisateurs.
- **Suppression en cascade** : ON DELETE CASCADE appliqué sur les clés étrangères de la table lignes_commande pour éviter les données orphelines.

Gestion des Sessions

Helpers centralisés



Les helpers de session sont regroupés dans config/. Ils offrent des fonctions standardisées pour démarrer, lire et détruire la session PHP depuis n'importe quel module du projet.

Sécurisation



La session est régénérée après chaque connexion réussie à l'aide de la fonction `session_regenerate_id(true)` pour prévenir le vol de session. Les accès au back-office vérifient systématiquement la présence de `admin_id` et la validité du rôle en session.

Protection CSRF



Protection contre les Failles CSRF (Cross-Site Request Forgery)
Un token CSRF unique est généré via la fonction `generateCSRFToken()` et stocké en session. Il est validé à chaque soumission de formulaire critique par la fonction `validateCSRFToken()` pour bloquer les attaques cross-site.

Authentification & Accès

🔒 Authentification : Vérification via `password_verify()`.

🛡️ Protection XSS : Application de `htmlspecialchars()` sur les sorties.

🚪 Contrôle d'accès : Redirection dynamique selon le rôle (`admin_id`).

Tests & Qualité

Fonctionnel



📱 Front & Back : Tests manuels sur l'ensemble des interfaces.

🕒 Parcours : Validation pas à pas de la navigation et de l'affichage.

📋 Formulaires : Vérification complète des flux utilisateurs.

Validation



🛒 Flux critiques : Tunnel d'achat & gestion du panier (ajout/suppr).

📝 Formulaires : Contrôle des retours serveur (contact, privatisation).

🔄 Intégrité : Soumission et traitement des données sans erreur.

Journaux



📄 Logs PHP : Capture des erreurs dans php-errors.log.

🔧 Debug : Analyse ciblée et correction des requêtes préparées.

🛡️ Sécurité : Vérification des protections CSRF en conditions réelles.



Tests Front-End



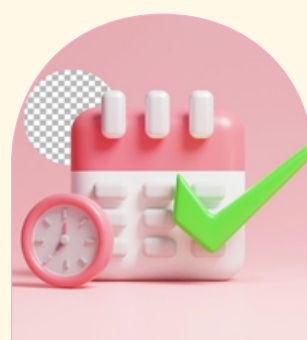
Formulaire Contact
Validation OK



Filtrage JS
Équipage &
Pensionnaires



Tunnel Commande
Ajout &
Suppression Panier



Privatisation
Demande &
Réservation

Tests Back-End



Capture PHP
Analyse des logs



Requêtes PDO
Jetons CSRF



Droits d'accès
Sécurité sessions



Correctifs ciblés
Stabilité serveur

Installation & Déploiement



Stack & Environnement



🖥️ Serveur : Laragon (Apache 2.4 / PHP 8.x)

🌿 Versionning : Git & GitHub (GitFlow)

🔧 IDE & Outils : VS Code + Intelephense / Prettier



Vérification (Recette)



🚀 Services : Démarrage Apache & MySQL

🌐 Accès local : localhost/repaire-des-moustaches/

✅ Validations : CSS, WebP & inclusions PHP

```
# 1. Clonage du dépôt distant
$ git clone https://github.com

# 2. Accès au dossier du projet
$ cd repaire-des-moustaches

# 3. Vérification des fichiers backend
$ ls -la includes/ css/ images/ index.php

# 4. Statut du déploiement
✓ Projet installé avec succès !
```

Annexes techniques

- 🔌 Base de données : Configuration via le pattern Singleton PDO.
- 🛡️ Sécurité CSRF : Fonctions `generateCSRFToken()` & `validateCSRFToken()`.
- 🛒 Business Logic : Traitement des commandes dans `checkout.php`.



Config Base de Données

📁 config/database.php — getPdo()

Pattern Singleton : garantit une connexion unique et réutilisable par requête.

Points clés :

🔒 DSN MySQL : Connexion sécurisée via PDO.

⚠️ Gestion d'erreurs :
PDO::ERRMODE_EXCEPTION avec bloc try/catch.

📊 Mode Fetch : PDO::FETCH_ASSOC défini par défaut.

🔄 Instance statique : Variable \$pdo réutilisée (évite la surcharge).

Avantages du Singleton :

⚡ Performance : 1 seule connexion par requête HTTP.

🔧 Maintenabilité : Point d'accès centralisé.

🛡️ Sécurité : Identifiants isolés dans le dossier config/.



Gestion CSRF & Sécurité

🔑 Génération du Token

⚙️ Méthode :

`generateCSRFToken()` avec
`bin2hex(random_bytes(32))`.



Stockage :

Enregistrement sécurisé
dans `$_SESSION['csrf_token']`.

🛡️ Validation & Contrôle

🕒 Comparaison : `hash_equals()`
dans `validateCSRFToken()` (anti
timing-attacks).

📋 Portée : Formulaires critiques
(commandes, connexion,
privatisation).

🔄 Cycle : Régénération à chaque
session & vérification serveur
stricte.



Insertion Commandes



 checkout.php — Processus de commande
Gestion des transactions SQL :

 Double insertion : Ajout dans commandes puis dans lignes_commande.

 Atomicité : Transactions SQL avec rollback automatique en cas d'erreur.

 Sécurité : Nettoyage via htmlspecialchars() et filter_var().

 Exceptions : Bloc try/catch/finally pour une gestion robuste PDO.



Difficultés Techniques & Solutions

🔧 admin/upload.php — Sécurité Fichiers

Problème : Injections de scripts via l'upload d'images de chats.

Solution : Contrôle binaire du Type MIME (finfo) & filtrage strict des extensions (.png, .jpg).

🛡️ public/review-submit.php — Protection XSS

Problème : Vulnérabilité XSS sur le mur des témoignages.

Solution : Échappement systématique via htmlspecialchars() avec le flag ENT_QUOTES.

🔑 admin/login.php — Sécurité Session

Problème : Risque de Session Fixation sur l'espace Admin.

Solution : Régénération forcée de l'ID via session_regenerate_id(true) après authentification.



Sécurité : Téléversement d'Images

```
public function uploadCatImage($file) {  
    // 1. Validation de l'absence d'erreurs d'upload  
    if ($file['error'] !== UPLOAD_ERR_OK) {  
        throw new Exception("Erreur lors de l'upload.");  
    }  
  
    // 2. Contrôle binaire du Type MIME réel (finfo)  
    $finfo = new finfo(FILEINFO_MIME_TYPE);  
    $mimeType = $finfo->file($file['tmp_name']);  
  
    $allowedMimeTypes = [  
        'image/jpeg' => 'jpg',  
        'image/png' => 'png',  
        'image/webp' => 'webp'  
    ];  
  
    if (!array_key_exists($mimeType, $allowedMimeTypes)) {  
        throw new Exception("Format non autorisé (Seuls JPG, PNG et WebP sont acceptés).");  
    }  
  
    // 3. Renommage aléatoire sécurisé & extension forcée  
    $extension = $allowedMimeTypes[$mimeType];  
    $safeName = bin2hex(random_bytes(16)) . '.' . $extension;  
    $destination = "../public/images/uploads/" . $safeName;  
  
    // 4. Déplacement sécurisé  
    move_uploaded_file($file['tmp_name'], $destination);  
    return $safeName;  
}
```

🛡️ Protection Unrestricted File Upload

Problème : Risque d'injection via l'extension déclarée dans
\$_FILES['name'] ou le type client (facilement falsifiables).

Solution appliquée :

Type MIME réel : Inspection binaire via finfo (finfo_file()).

Nommage sécurisé : Génération d'un nom aléatoire unique
(cryptographique).

Extension forcée : Alignée sur le type MIME réel détecté.





"Place aux échanges!"